Summary Post

The discussion helped me see the limits of CVSS more clearly. It also showed why thinking about the specific organisation matters when deciding which problems to tackle first. In my first post, I said the system can be tricky because some metrics require people to judge them. Wunder et al. found that users often disagree on Attack Vector, User Interaction, and Scope too. This means the scores might not line up even when the method is the same. I think that is the part that stands out. It feels like consistency could be a bigger issue than it seems at first.

The peer conversations also highlighted the distinction between vulnerability severity and organisational risk. Technical severity is indicated by a high CVSS score; however, this does not always imply that a vulnerability poses the most immediate danger to a given organisation. Aven and Thekdi (2025) stress how crucial it is to take context and uncertainty into account when evaluating risk. This has strengthened my belief that there should be more than one numerical score used in vulnerability prioritisation.

Another key point was the adoption of EPSS. Focusing on the possibility of exploitation, EPSS can assist organisations in identifying vulnerabilities that need immediate action. I now see, though, that CVSS does not necessarily need to be entirely replaced. While EPSS and SSVC can give more context, CVSS can still offer helpful information on technical severity.

Overall, I now realise that technical severity, possibility of exploitation, and organisational context should all be taken into account when prioritising vulnerabilities. This can assist security teams in making more informed choices and making better use of the limited resources available for remediation.

References

Aven, T. and Thekdi, S. (2025) *Risk Science*. 3rd edn. Abingdon: Routledge.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding Light on CVSS Scoring Inconsistencies: A User-Centric Study on Evaluating Widespread Security Vulnerabilities', *2024 IEEE Symposium on Security and Privacy (SP)*, pp. 1102–1121. doi: 10.1109/SP54263.2024.00058.